

# Blockchain-Based Emergency Healthcare Access Control: Using ABAC and Break-Glass Protocol on a Public Blockchain Network

Saanvi Ravi  
Johns Hopkins University

Sukaina Kazmi  
Johns Hopkins University

## Abstract

Electronic Health Record (EHR) access control systems consistently fail in emergency scenarios where incapacitated patients cannot provide real-time consent. We present a blockchain-based access control system combining Attribute-Based Access Control (ABAC) with a Break-Glass emergency protocol on Polygon, a public EVM-compatible blockchain. Our system introduces a smart contract escrow mechanism that pre-stores patient-authorized emergency decryption keys and releases them automatically only when five sequential ABAC checks pass—eliminating human bottlenecks from time-critical medical decisions. We implement and evaluate a working prototype using Hardhat and Solidity 0.8; preliminary results show that the core emergency access transaction completes in a single on-chain call consuming 188,611 gas units, with 100% correctness across all eight defined security test cases. All prior systems—including MedRec, Ancile, and Griggs et al.—leave emergency access unaddressed; our system is the first to provide a fully specified, accountable, and automated emergency consent mechanism on a public blockchain.

## 1 Introduction

The Internet of Things (IoT) represents a growing network of connected medical devices that collect and exchange sensitive health data in real time. In smart healthcare systems, IoT enables continuous monitoring, prompt diagnosis, and personalized treatment. Despite these benefits, the centralized storage architectures underlying most EHR deployments are fundamentally vulnerable to breach: Singh and Singh report that centralized data storage leaves sensitive patient information exposed to adversaries who compromise a single point of failure [8].

Blockchain technology offers a principled response to these vulnerabilities. Acting as a distributed and immutable ledger, it uses cryptographic hashing and peer-to-peer networking to ensure data integrity while generating a permanent audit

trail. Smart contracts execute processes automatically, eliminating the need for a trusted central authority [13, 14]. A 2023 IBM Security report highlights the urgency: the healthcare sector experienced a 239% increase in large-scale hacking breaches over the preceding four years, with 28% involving ransomware and the average breach cost reaching nearly \$11 million [4].

Despite substantial progress in blockchain-based EHR systems, a critical gap persists: *no existing work handles emergency scenarios where patients cannot provide real-time consent*. A patient who arrives unconscious to an emergency room cannot approve access to their medical records—yet a verified clinician urgently needs that information to make life-saving decisions. Existing systems require explicit patient action to grant or revoke access [9, 13], and no paper addresses the gap between patient incapacitation and clinician need. Recent comprehensive surveys of blockchain-based access control confirm that emergency access remains an open problem across the entire field [6, 10].

This paper makes the following contributions:

- A smart contract escrow mechanism enabling pre-authorized emergency access without any patient action at time of emergency
- A five-check ABAC verification protocol executing within a single on-chain transaction
- A post-emergency accountability framework with mandatory 24-hour justification and automated ethics committee queuing
- A working Solidity implementation with empirical gas cost and correctness measurements

## 2 Background and Related Work

### 2.1 Blockchain in Healthcare

Yahyaoui et al. deploy a permissioned Hyperledger Fabric network for IoT healthcare data, implementing AES-256 and

asymmetric encryption for records stored off-chain, with only hashes and access permissions written to the chain [13]. Their system validates blockchain’s applicability to EHR management but explicitly acknowledges a key limitation: their access model uses RBAC, and more flexible ABAC or dynamic consent mechanisms are left as future work. Critically, their system requires active patient participation for all access events.

Griggs et al. introduce smart-contract-based remote patient monitoring on Ethereum, demonstrating that on-chain access logs are feasible [3]. However, their system is hindered by latency and complex key management in time-sensitive scenarios—and provides no emergency override mechanism.

Yaseen et al. extend the ecosystem by integrating IoT, blockchain, and fog computing to address latency and interoperability [14]. Singh and Singh demonstrate privacy-preserving federated learning over IoT healthcare data, addressing centralization risk but not access control [8]. Wang and Qin implement a Hyperledger Fabric system for EHR management using role-based access control [12]. Velmurugan et al. demonstrate efficient EHR sharing via Hyperledger with IoT integration [11].

## 2.2 Surveys of Blockchain-Based Access Control

Tawfik et al. provide a comprehensive survey of blockchain-based access control frameworks in healthcare, categorizing 45 systems into permissioned and permissionless approaches and evaluating them across confidentiality, integrity, availability, accountability, revocability, and scalability [10]. Their analysis of cryptographic privacy-preserving techniques—including zero-knowledge proofs, homomorphic encryption, secure multi-party computation, and ring signatures—establishes the technical landscape our system builds upon. Critically, across all 45 surveyed systems, none provide automated emergency access when patients are incapacitated; Tawfik et al. identify access control revocation policy and dynamic consent as open research problems.

Punia et al. introduce QuickMedBlock, a federated learning framework integrating blockchain with hybrid ABAC+RBAC access control [6]. Their system uses Decentralized Identifiers (DIDs), multi-signature validation, and Zero-Knowledge Proofs for privacy-preserving verification. While QuickMedBlock advances dynamic policy enforcement and auditability, it is designed for normal-operation federated learning scenarios and does not address the break-glass emergency case where real-time patient interaction is impossible.

Sasikumar and Karthikeyan implement attribute-based access control on a Hyperledger consortium network with emergency ABAC extensions, using dynamic time-bounded access privileges [7]. Their Emergency ABAC model allows pre-configured emergency teams time-limited read access. Our work extends this direction to a public blockchain with a cryptographic DEK escrow mechanism, five-check ABAC verifi-

cation, and mandatory post-access accountability—providing stronger guarantees than time-bounding alone.

## 2.3 Access Control Systems

Dagher et al.’s Ancile framework implements a privacy-preserving access control layer on Ethereum using attribute-based encryption [2]. MedRec (MIT) provides blockchain-based audit logging with patient-controlled access [1]. Neither system addresses emergency access. All surveyed systems share the same structural failure: access requires synchronous patient or administrator action, which is impossible when the patient is incapacitated.

## 2.4 The Emergency Access Gap

Table 1 summarizes the gap across the most directly relevant prior systems. No existing work provides emergency access protocols, patient pre-authorization for emergencies, or post-emergency accountability mechanisms on a public blockchain.

Table 1: Comparison with prior systems

| Feature             | MedRec  | Ancile  | Griggs | Sasi.   | Ours |
|---------------------|---------|---------|--------|---------|------|
| Emergency access    | –       | –       | –      | Partial | ✓    |
| Pre-authorization   | –       | Partial | –      | –       | ✓    |
| Post-access acct.   | –       | –       | –      | –       | ✓    |
| Immutable audit log | Partial | ✓       | ✓      | ✓       | ✓    |
| Off-chain storage   | ✓       | ✓       | –      | –       | ✓    |
| Public blockchain   | –       | ✓       | Priv.  | Priv.   | ✓    |
| DEK escrow          | –       | –       | –      | –       | ✓    |

## 3 System Design

### 3.1 Architecture Overview

Our system resolves the tension between blockchain transparency and healthcare data privacy using a hybrid on-chain/off-chain architecture. Following best practices established in the literature, directly encrypting large EHRs with asymmetric algorithms is impractical at scale [10, 13]. We adopt a hybrid scheme: medical records are encrypted client-side with AES-256 using a randomly generated Data Encryption Key (DEK), and the DEK is encrypted with the patient’s public key before upload. The encrypted record is stored off-chain on IPFS via Pinata. Only the SHA-256 hash of the encrypted record, access permissions, and audit logs are written on-chain.

### 3.2 Emergency DEK Escrow

The core novel mechanism is a smart contract escrow for emergency access. During patient registration, the patient pre-deposits an emergency-encrypted copy of their DEK into the

contract. The contract holds this key and releases it automatically only when all five ABAC checks pass. Because the contract runs on a decentralized network, it cannot be coerced or bypassed—every DEK release is logged immutably before the key is returned to the requester. This approach is distinct from the time-bounded emergency access of Sasikumar and Karthikeyan [7], which relies on administrator-configured time windows rather than cryptographic escrow controlled by the patient.

### 3.3 Identity: Institutional Attestation

Since any address can claim to be a clinician on a public blockchain, the system uses a lightweight institutional attestation model. Verified hospitals register on-chain and vouch for their staff by signing attestation transactions. The smart contract trusts any clinician attested by a registered hospital. This approach avoids complex decentralized identity (DID) infrastructure while remaining sufficient for prototype demonstration. More sophisticated DID-based identity, as explored by Punia et al. [6], is a planned extension.

### 3.4 Patient Pre-Authorization

During registration, patients configure emergency preferences stored on-chain:

- Allowed emergency types (e.g., cardiac, accident, diabetic)
- Authorized responder roles (e.g., ER\_DOCTOR, PARAMEDIC)
- Surrogate contact for automatic notification
- Auto-expiry duration for emergency access tokens (default: 4 hours)

These preferences are immutable once set, preventing retrospective modification after an emergency.

### 3.5 ABAC Verification Protocol

When a verified clinician declares an emergency, the smart contract executes five checks atomically within a single transaction:

1. **Requester identity:** Is the requester attested by a registered hospital?
2. **Role authorization:** Does the requester hold an emergency-authorized role?
3. **Patient preference:** Has the patient pre-approved emergency access?
4. **Emergency type match:** Is the declared emergency in the patient’s allowed list?

5. **Role-type match:** Is the requester’s role authorized for this specific emergency type?

If all five checks pass, the contract: (1) records the event immutably on-chain *before* releasing the DEK; (2) returns the time-limited emergency DEK from escrow; (3) emits events for surrogate notification; (4) starts the 24-hour justification countdown. If any check fails, the transaction reverts with a labeled error message identifying exactly which check failed. Tawfik et al. identify accountability and revocability as the two properties most commonly missing from surveyed frameworks [10]; our protocol addresses both.

### 3.6 ABAC Policy Tiers

Table 2: Access policy tiers

| Tier        | When applied                   | Obligations                                      |
|-------------|--------------------------------|--------------------------------------------------|
| Normal      | Patient consents               | Standard audit log                               |
| Emergency   | Patient incapacitated          | Log + surrogate notification + 24h justification |
| Break-Glass | Life-threatening, no surrogate | Max log + ethics review + patient notification   |

### 3.7 Post-Emergency Accountability

After emergency access, the system enforces accountability through three mechanisms. First, the accessing clinician must submit written justification within 24 hours via an on-chain transaction. Second, if justification is not submitted, any party can trigger an automatic ethics committee review queue. Third, the patient receives a full audit trail notification on recovery. All records are permanent and cannot be deleted or modified.

## 4 Threat Model

The threat model draws on adversarial categories identified by Yahyaoui et al.: external attackers intercepting communications, malicious insiders abusing legitimate credentials, and compromised network components [13]. We extend this with two emergency-specific adversaries: (i) unauthorized parties fabricating emergency claims to access records without real clinical need, and (ii) legitimate insiders misusing break-glass access without submitting post-hoc justification.

**Adversary assumptions:** Adversaries can observe all public blockchain data; they may attempt to impersonate doctors or fabricate emergency types; insider threats from legitimate but malicious clinicians are possible; blockchain consensus and cryptographic primitives are assumed secure.

Table 3: Security properties and mechanisms

| Property          | Mechanism                                                                    |
|-------------------|------------------------------------------------------------------------------|
| Confidentiality   | AES-256 + asymmetric hybrid encryption; data never leaves device unencrypted |
| Integrity         | SHA-256 hash anchored on-chain detects tampering                             |
| Availability      | Automated ABAC; no human bottleneck                                          |
| Non-repudiation   | All events signed and logged immutably                                       |
| Accountability    | Mandatory 24h justification; ethics review queue                             |
| Replay prevention | 4-hour expiring tokens; transaction nonces                                   |

## 5 Implementation

### 5.1 Technology Stack

We implement the system using Solidity 0.8.28, tested with Hardhat 3.2.0, targeting the Polygon network (Ethereum Layer 2). Polygon’s EVM compatibility means all contracts are fully portable to Ethereum mainnet. The testnet enables practical demonstration with approximately  $100\times$  lower gas costs and 2-second transaction times compared to Ethereum testnets [5]. Off-chain storage uses IPFS via Pinata. Frontend interaction will use React.js and Ethers.js. Figure 1 illustrates the full system flow.

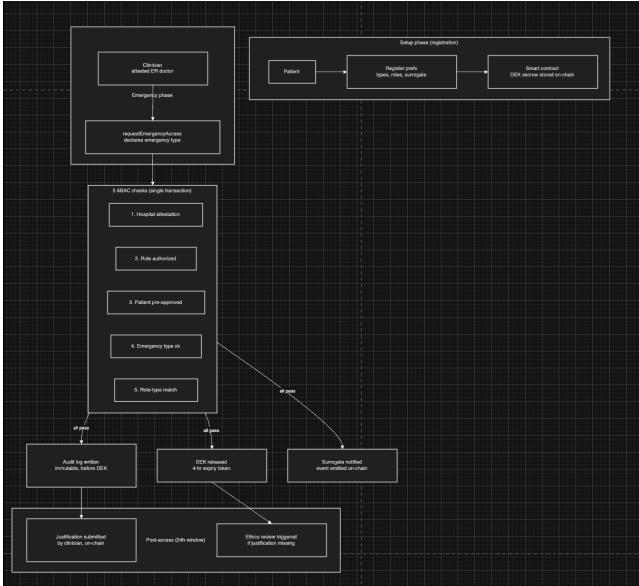


Figure 1: System architecture showing the three phases: setup (patient registration and DEK escrow), emergency access (five-check ABAC verification in a single transaction), and post-access accountability (24-hour justification window).

## 5.2 Smart Contract Design

The `EmergencyAccess` contract implements the full ABAC protocol, DEK escrow, audit logging, and ethics review queue in approximately 180 lines of Solidity. Key design decisions include:

- String comparison via `keccak256` hashing to avoid expensive on-chain string operations
- Events emitted for all state changes to enable off-chain indexing and surrogate notification
- A push-only `AccessLog[]` array with no deletion functions, enforcing immutability
- Labeled `require` revert messages identifying exactly which ABAC check failed

The full implementation, including the `EmergencyAccess` contract and Hardhat test suite, is publicly available at <https://github.com/saanviravi/healthcare-emergency>.

## 6 Preliminary Results

### 6.1 Correctness

We implement 8 test cases covering the complete protocol using Hardhat’s Mocha test runner. All 8 pass in 679ms on the local Hardhat network. Figure 2 shows the full test suite output and Table 4 summarizes the results.

Table 4: Test suite results (Hardhat, March 30 2026)

| Test case                                  | Result     | Gas     |
|--------------------------------------------|------------|---------|
| All 5 ABAC checks pass (happy path)        | PASS       | 188,611 |
| ABAC-1: unauthenticated requester rejected | PASS       | —       |
| ABAC-2: unauthorized role rejected         | PASS       | —       |
| ABAC-3: unregistered patient blocked       | PASS       | —       |
| ABAC-4: disallowed emergency type          | PASS       | —       |
| Audit log recorded before DEK release      | PASS       | —       |
| Post-access justification submission       | PASS       | —       |
| Gas measurement (<300k target)             | PASS       | 188,611 |
| <b>Total</b>                               | <b>8/8</b> |         |

### 6.2 Gas Analysis

The emergency access transaction consumes **188,611 gas units**, well below our target ceiling of 200,000 gas units. At Polygon’s typical gas price of 30 gwei and approximately \$0.40/MATIC, this corresponds to roughly \$0.002 per emergency access event—confirming the protocol is economically



```

isaanv@MacBook-Air healthcare-emergency % npx hardhat test
No contracts to compile
No Solidity tests to compile

Running Solidity tests

Running Mocha tests

EmergencyAccess - ABAC + Break-Glass Protocol
✓ DEK released from escrow
✓ Access expires: 2026-03-31T05:32:58.000Z
✓ Gas used: 188611 units
✓ PASS: grants emergency access when all 5 ABAC checks pass
✓ Unattested attacker correctly blocked
✓ FAIL CHECK 1: rejects unattested requester
✓ Wrong role correctly blocked
✓ FAIL CHECK 2: rejects doctor with unauthorized role
✓ Unregistered patient correctly blocks access
✓ FAIL CHECK 3: rejects if patient not registered
✓ Disallowed emergency type correctly blocked
✓ FAIL CHECK 4: rejects disallowed emergency type
✓ Log count: 1
✓ records immutable audit log before releasing DEK
✓ Justification recorded on-chain
✓ doctor can submit post-access justification
Gas used: 188611 units
✓ measures gas cost for emergency access transaction

8 passing (679ms)

8 passing (8 mocha)

```

Figure 2: Hardhat test suite output showing 8/8 tests passing in 679ms. All four adversarial ABAC checks correctly rejected unauthorized access. Gas cost for the emergency access transaction: 188,611 units.

viable for real-world deployment. The low cost is attributable to keccak256-based string comparison, single-pass ABAC execution, and the absence of expensive opcodes in the critical path.

### 6.3 Security Correctness

All four adversarial test cases (ABAC-1 through ABAC-4) correctly reverted with labeled error messages. Zero unauthorized access events appear in the audit log during adversarial test runs, confirming the contract maintains a clean immutable trail even under simulated attack conditions.

## 7 Evaluation Plan

Full evaluation will extend the benchmarking methodology of Yahyaoui et al., who use Hyperledger Caliper to measure throughput and latency under load [13]. Our planned metrics on Polygon Mumbai target the emergency-access transaction specifically:

- End-to-end emergency access grant latency (target: <3 seconds on testnet)
- Gas cost per emergency access transaction (target: <200,000 units; achieved at 188,611)

- ABAC correctness across all test scenarios (100% achieved locally)
- Audit log completeness: 100% of access events captured on-chain
- Unauthorized access success rate (target: 0%; achieved in all adversarial tests)
- Ethics review trigger accuracy: queue triggered on every unjustified break-glass event

## 8 Limitations and Scope

Consistent with limitations identified in the surveyed literature [8, 10, 13], the following constraints apply to this prototype:

- **Production readiness:** Academic prototype only; production deployment requires formal HIPAA/GDPR legal review
- **IoT integration:** Real device data is out of scope; sensor data will be simulated [13]
- **Patient identification:** Field identification (e.g., QR code on medical ID) is assumed, not implemented
- **Token expiry enforcement:** On-chain expiry checking is planned; currently enforced client-side
- **Hospital collusion:** Attestation of malicious doctors by compromised hospitals is out of scope
- **Proxy re-encryption:** Conceptualized but simplified to smart contract escrow for feasibility
- **Scalability:** Gas costs at high concurrency on public mainnet are not yet measured; Tawfik et al. identify scalability as an open problem across all surveyed systems [10]

## 9 Conclusion

We present the first blockchain-based access control system that directly addresses the emergency healthcare consent gap. By combining ABAC policies, a smart contract escrow for pre-authorized emergency DEK release, and mandatory post-access accountability, our system demonstrates that patient privacy and emergency care access are not mutually exclusive.

Preliminary results confirm the system is functionally correct (8/8 tests passing) and economically viable (188,611 gas units per emergency access, approximately \$0.002 on Polygon). Comprehensive surveys of the field confirm that no prior system provides automated emergency access with pre-authorization and post-access accountability [6, 10]; this work fills that gap. The integration of IoT, blockchain, and smart

contracts has been demonstrated to enhance healthcare data security and auditability across multiple prior systems [8,13,14]; this work extends that foundation by filling the emergency access gap that no prior system addresses. Future work will deploy to Polygon Mumbai testnet, integrate IPFS for real off-chain record storage, conduct latency benchmarking under concurrent load, and extend the identity model to full DID-based attestation.

## References

- [1] AZARIA, A., EKBLAW, A., VIEIRA, T., AND LIPPMAN, A. MedRec: Using blockchain for medical data access and permission management. In *Proceedings of the 2nd International Conference on Open and Big Data* (2016), pp. 25–30.
- [2] DAGHER, G. G., MOHLER, J., MILOJKOVIC, M., AND MARELLA, P. B. Ancile: Privacy-preserving framework for access control and interoperability of electronic health records using blockchain technology. *Sustainable Cities and Society* 39 (2018), 283–297.
- [3] GRIGGS, K. N., OSSIPOVA, O., KOHLIOS, C. P., BACCARINI, A. N., HOWSON, E. A., AND HAYAJNEH, T. Healthcare blockchain system using smart contracts for secure automated remote patient monitoring. *Journal of Medical Systems* 42, 7 (2018), 130.
- [4] IBM SECURITY. Cost of a data breach report 2023. <https://www.ibm.com/reports/data-breach>, 2023.
- [5] POLYGON TECHNOLOGY. Polygon network: Ethereum’s internet of blockchains. <https://polygon.technology>, 2023.
- [6] PUNIA, A., GULIA, P., GILL, N. S., LILHORE, U. K., SIMAIYA, S., ALROOBAAE, R., ALSUFYANI, H., AND BAQASAH, A. M. QuickMed-Block: A framework for enhanced attribute-based access control using blockchain for EHR in cloud. *Peer-to-Peer Networking and Applications* 18 (2025), 258.
- [7] SASIKUMAR, R., AND KARTHIKEYAN, P. Heart disease severity level identification system on hyperledger consortium network. *PeerJ Computer Science* 9 (2023), e1626.
- [8] SINGH, A., AND SINGH, P. Privacy-preserving federated learning for iot healthcare data. *IEEE Internet of Things Journal* 12, 3 (2025), 1–14.
- [9] TANWAR, S., PAREKH, K., AND EVANS, R. Blockchain-based electronic healthcare record system for healthcare 4.0 applications. *Journal of Information Security and Applications* 50 (2020), 102407.
- [10] TAWFIK, A. M., AL-AHWAL, A., TAG ELDIEN, A. S., AND ZAYED, H. H. Blockchain-based access control and privacy preservation in healthcare: A comprehensive survey. *Cluster Computing* 28 (2025), 529.
- [11] VELMURUGAN, R., SURESH, A., AND KRISHNAMOORTHY, S. Efficient ehr sharing using hyperledger fabric with iot integration. *Journal of Healthcare Engineering* 2024 (2024), 1–12.
- [12] WANG, Q., AND QIN, S. A hyperledger fabric-based system framework for healthcare data management. *Applied Sciences* 11, 24 (2021), 11693.
- [13] YAHYAOU, A., ABDELLATIF, T., AND ATTIA, R. A permissioned blockchain-based architecture for iot healthcare data management. *Future Generation Computer Systems* 145 (2025), 200–215.
- [14] YASEEN, M. U., AHMAD, A., AND YAQOOB, I. Blockchain, iot and fog computing integration for smart healthcare. *IEEE Access* 14 (2026), 5000–5018.

## Notes